



Hvor modstandsdygtig er din virksomhed mod phishing?

Brug denne 16-punkts selvevaluering til at teste jeres organisations forsvar mod phishing-angreb. Hvert punkt afspejler en kontrol der matcher NIS2's awareness-krav og reelle trusler mod SMV'er i EU. 1 point pr. afkrydsning.

1. Genkendelse af phishing

- ☐ **Medarbejdere verificerer afsenderens faktiske e-mailadresse, ikke kun det viste navn**
Phishingmails forfalsker ofte kendte navne, mens den reelle adresse er en anden.
- ☐ **Uventet hastværk eller pres behandles som et advarselstegn**
Sætninger som "handl nu" eller "betaling haster" er klassiske advarselstegn.
- ☐ **Medarbejdere holder musen over links for at verificere destinationen før de klikker**
Det reelle domæne afviger ofte fra det viste — fx nordea-login.dk vs. nordea.dk.
- ☐ **Vi er forsigtige med uventede vedhæftede filer, selv fra kendte afsendere**
Kompromitterede konti bruges rutinemæssigt til at sende malware til eksisterende kontakter.

2. E-mail- og kontosikkerhed

- ☐ **Multifaktor-autentificering er aktiveret på alle e-mail- og forretningskonti**
Reducerer drastisk risikoen for kontoovertagelse selv hvis adgangskoden bliver phished.
- ☐ **SPF, DKIM og DMARC er konfigureret korrekt på vores e-maildomæne**
Forhindrer angribere i at forfalske jeres domæne i deres phishing-kampagner.
- ☐ **Lignende domæner overvåges eller blokeres ved e-mail-gatewayen**
Varianter som soroflovv.com eller soroflow-support.com — registrér og overvåg dem.



3. Awareness & træning

- ☐ **Phishing-awareness-træning gennemføres mindst én gang om året**
NIS2 Artikel 21 kræver regelmæssig cybersikkerhedstræning for alle medarbejdere og ledelse.
- ☐ **Medarbejdere har en klar og let måde at rapportere mistænkelige e-mails**
En "Rapportér phishing"-knap, en dedikeret postkasse eller en navngiven IT-kontakt.
- ☐ **Nye medarbejdere modtager phishing-awareness-træning under onboarding**
Vent ikke til den årlige cyklus — etabler sikkerhedsbevidsthed fra dag ét.

4. Hændelseshåndtering

- ☐ **Vi har en skriftlig procedure for hvad man gør hvis nogen klikker på et phishing-link**
Hastighed er afgørende: isoler enheden, skift adgangskoder, underret IT, gennemgå aktivitetslogs.
- ☐ **Adgangskoder kan nulstilles og aktive sessioner inddrages hurtigt for kompromitterede konti**
Nødvendigt for at inddæmme kontoovertagelse før yderligere skade sker.
- ☐ **Rapporterede phishing-forsøg logges og gennemgås**
Mønstre afslører målrettede kampagner og informerer fremtidige træningstemaer.

5. Test & løbende forbedring

- ☐ **Vi gennemfører simulerede phishing-kampagner for at teste medarbejdernes parathed**
NIS2 best practice — afslører huller i den virkelige verden før reelle angribere gør.
- ☐ **Vi måler vores klikrate over tid og arbejder på at reducere den**
Et almindeligt mål: en klikrate under 5% inden for 12 måneder.
- ☐ **Medarbejdere informeres om aktuelle trusler målrettet danske SMV'er**
MitID-svindel, e-Boks-efterspørgelse, falske fakturaer fra "DSB" eller "PostNord".

Hvordan scorede du?

13–16	Stærkt forsvar	Book et opkald og finpuds jeres awareness-program
8–12	Tydelige huller	Medarbejdere kan være sårbare — håndtér snart
0–7	Høj eksponering	Phishing er jeres mest sandsynlige angrebsvej

Ved du ikke hvor du skal starte?

Book et gratis 20-minutters møde. Vi gennemgår jeres situation og fortæller jer ærligt hvad der bør gøres — ingen jargon, ingen forpligtelser.
calendly.com/hello-soroflow/20min →

